

設定跨網站和 Android 應用程式的憑證整合共用

來源：<https://codelabs.developers.google.com/seamless-credential-sharing?hl=zh-tw>

步驟數：6

目錄

1. [總覽](#)
2. [使用 Google Play 管理中心設定 \(建議做法\)](#)
3. [使用 Digital Asset Links 手動設定](#)
4. [驗證設定](#)
5. [在多個網站之間共用憑證](#)
6. [結論](#)

1. 總覽

使用者是否透過網站和 Android 應用程式存取您的服務？如果使用者必須在每個平台分別登入，會造成不必要的阻礙，導致使用者流失。

[數位資產連結 \(DAL\)](#) 可讓您宣告網站與應用程式之間的關聯，解決這個問題。這樣一來，Google 密碼管理工具等密碼管理工具就能彼此分享儲存的密碼和密碼金鑰。

具體來說，設定 Digital Asset Links 檔案時，需要根據要分享的內容設定不同的關係：

- 密碼：包括 `delegate_permission/common.get_login_creds` 可讓密碼管理工具在網站和應用程式之間共用已儲存的密碼。
- 密碼金鑰：由於密碼金鑰會嚴格綁定特定網域，因此 Android 必須驗證網域擁有權。因此，您必須加入 `delegate_permission/common.handle_all_urls`。您可能會發現這是 Android 應用程式連結 (深層連結) 使用的權限，但這也是嚴格的必要條件，可讓您在一個平台建立密碼金鑰，並在另一個平台使用。

因此，使用者只要在其中一個平台儲存密碼或密碼金鑰，就能在所有相關聯的平台上順暢登入。



實作憑證整合共用功能，可大幅提升使用者體驗。舉例來說，[eBay 導入 DAL 進行憑證共用後，登入成功率提高了 10%](#)。

在本程式碼研究室中，您將瞭解如何使用 Digital Asset Links，在網站和 Android 應用程式之間啟用憑證共用功能。

必要條件

- 具備 JSON 和 Android 開發作業的基本知識。
- 熟悉 [Android Credential Manager 的必要條件](#)。

課程內容

- 如何使用 Google Play 管理中心設定憑證共用功能 (建議做法)。
- 如何手動建立 `assetlinks.json` 檔案。
- 如何設定 Android 應用程式以進行手動關聯。
- 如何將 Android 應用程式與網站網域建立關聯，以啟用密碼金鑰。
- 如何使用工具產生及驗證設定。

軟硬體需求

- 網站：能夠在 `https://{your-domain}/.well-known/assetlinks.json` 代管 JSON 檔案。

- **Android 應用程式：**
 - **Play 管理中心方法：**在 Google Play 發布的應用程式。
 - **手動方法：**可修改及建構的 Android 專案。請注意，應用程式必須在 Google Play 上發布，才能與 Google 密碼管理工具共用憑證。

運作方式

如要共用憑證，您必須建立雙向信任關係：

1. **網站 -> 應用程式：**您的網站必須代管 `assetlinks.json` 檔案，聲明信任您的 Android 應用程式。
2. **應用程式 -> 網站：**您必須設定 Android 應用程式，使其信任您的網站。

我們會介紹兩種做法：使用 Google Play 管理中心**自動建立** (建議)，以及直接使用 Digital Asset Links **手動建立**。

2. 使用 Google Play 管理中心設定 (建議做法)

如要啟用網站與 Android 應用程式之間的憑證共用功能，最簡單的方法是透過 Google Play 管理中心。使用這個方法，您不必修改應用程式資訊清單或發布新版應用程式，就能將應用程式與網站建立關聯。Google Play 會為您管理應用程式端的關聯。

必要條件

- 存取「[深層連結](#)」頁面的 Play 管理中心權限。
- 能夠在網域中發布 `/.well-known/assetlinks.json` 檔案。

如要進一步瞭解深層連結，請參閱「[Android 應用程式連結](#)」。

步驟

1. 在 **Play 管理中心**，依序前往「拓展」>「深層連結」。
2. 如果畫面上未列出您的網域，請按一下「應用程式設定」下方的「新增網域」。
3. 找到您的網域，然後找出「憑證共用」欄。按一下「開啟」（或確認新網域已開啟「啟用憑證共用功能」）。
4. 複製 Play 管理中心產生的 JSON 片段。
5. 將此 JSON 內容發布至 `https://{your-domain}/.well-known/assetlinks.json`。（如果已有這個檔案，請將新聲明附加到檔案中）。
6. 返回 Play 管理中心，然後按一下「建立網站關聯」或「開啟憑證共用功能」。

Play 管理中心現在會驗證您的代管設定。

 Google Play Console

Search Play Console

 All applications

Dashboard

Deep links

Monitor how well deep links are working for your users. [Show more](#)

Add domain

Follow the steps below to generate and publish a JSON file. Once you have completed these steps, create a website association with your domain to start viewing web-crawled URLs.

Step 1: Add domain details

Use the code example as a guide and update with your domain name

Domain

A short description for your app. Users can expand to view your full description.

Step 2. Copy the generated JSON file

Use the code example as a guide and update with your domain name

☒ Enable credential sharing

Credentials will be shared between your website and your app

```
[{
  "relation": ["delegate_permission/common.handle_all_urls"],
  "target": {
    "namespace": "android_app",
    "package_name": "com.domain.example",
    "sha256_cert_fingerprints": [
      "F0:FD:6C:5B:41:0F:25:CB:25:C3:B5:33:46:C8:97:2F:AE:30:F8:EE:74:11:DF:91:04:80:AD:6B:2D:60:DB:83",
      "AB:CD:6C:5B:41:0F:25:CB:25:C3:B5:33:46:C8:97:2F:AE:30:F8:EE:74:11:DF:91:04:80:AD:6B:2D:60:45:12"
    ]
  }
}]
```

Step 3: Publish the JSON file to this location

Once you have published, create a website association to view web-crawled URLs

Creating website association

如要啟用憑證共用功能，網站主機必須符合下列規定：

- 網址可透過 **HTTPS** 存取。
- 伺服器會傳回 `Content-Type: application/json`。
- 網址可直接存取，無須重新導向。

驗證完成後，憑證共用功能就會啟用。設定變更可能需要 1 到 2 週才會生效。

3. 使用 Digital Asset Links 手動設定

需要更多自主權？或是無法存取 Play 管理中心？您可以手動設定網站與 Android 應用程式之間的憑證共用。這項作業主要包含兩項工作：在網站上代管 JSON 檔案，以及更新 Android 應用程式資訊清單。

重要事項：如要讓 Google 密碼管理工具與應用程式共用憑證，即使您手動設定 Digital Asset Links，應用程式也必須發布至 Google Play。如果應用程式是在本機建構，但未在 Google Play 發布，就無法使用憑證共用功能。

1. 取得應用程式的數位指紋

設定憑證整合共用功能前，請確認您已為每個平台備妥下列項目：

針對每個 Android 應用程式：

- [Android 應用程式 ID](#)，如應用程式的 `build.gradle` 檔案中所聲明。
- 簽署憑證的 [SHA256 指紋](#)。
- (建議) 使用 [Credential Manager API](#) 實作使用者登入功能。

2. 建立關聯檔案

您需要建立 `assetlinks.json` 檔案，宣告網站和應用程式之間的關係。使用 `delegate_permission/common.get_login_creds` 授予共用密碼的權限，並使用 `delegate_permission/common.handle_all_urls` 啟用深層連結和共用密碼金鑰。

建立名為 `assetlinks.json` 的檔案，並在其中加入下列內容：**取代範例值**，改用您自己的網站網址、套件名稱和指紋：

```
[{
  "relation": [
    "delegate_permission/common.handle_all_urls",
    "delegate_permission/common.get_login_creds"
  ],
  "target": {
    "namespace": "android_app",
    "package_name": "com.example.app",
    "sha256_cert_fingerprints":
      ["14:6D:E9:83:C5:73:06:50:D8:EE:B9:95:2F:34:FC:64:16:A0:83:42:E6:1D:BE:A8:8A:04:96:B2:3F:CF:4
      4:E5"]
  }
}]
```

`sha256_cert_fingerprints` 是陣列，因此您可以視需要加入多個簽署金鑰的指紋 (例如偵錯和發布金鑰，或不同應用程式版本的金鑰)。

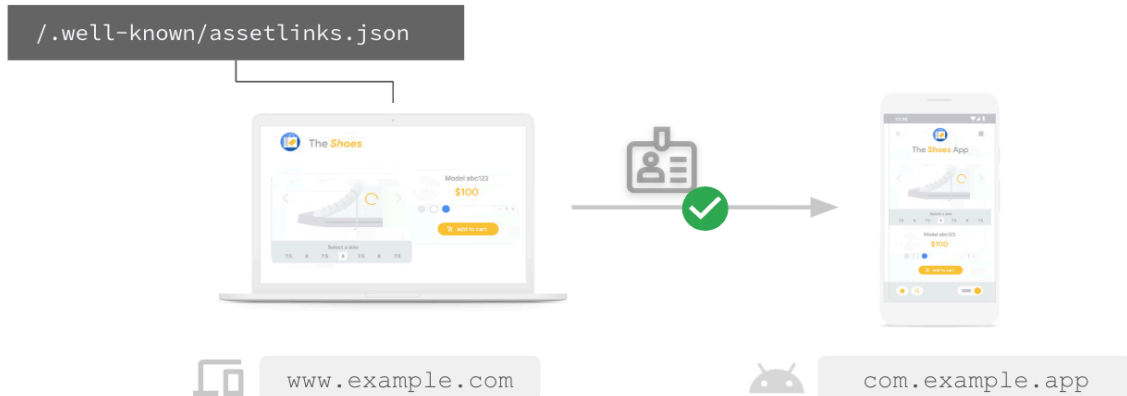
3. 代管檔案

將 `assetlinks.json` 檔案上傳至網域根目錄的 `.well-known` 目錄。

地區：`https://{your-domain}/.well-known/assetlinks.json`

如要啟用憑證共用功能，網站主機必須符合下列規定：

- 網址可透過 **HTTPS** 存取。
- 伺服器會傳回 `Content-Type: application/json`。
- 網址可直接存取，無須重新導向。



4. 設定 Android 應用程式

現在，請告知 Android 應用程式信任該網站。您會在資訊清單中新增參照，指向包含 `assetlinks.json` 網址的資源檔案。

1. 新增字串資源

在 `res/values/strings.xml` 中新增字串 `asset_statements`。請注意逸出的引號！

```
<resources>
    <string name="asset_statements" translatable="false">
        [{
            \"include\": \"https://www.example.com/.well-known/assetlinks.json\"
        }]
    </string>
</resources>
```

2. 將中繼資料新增至資訊清單

在 `AndroidManifest.xml` 中，在 `<application>` 元素內新增 `<meta-data>` 標記，參照這個字串資源：


```
<manifest xmlns:android="http://schemas.android.com/apk/res/android"
    package="com.example.app">

    <application
        android:allowBackup="true"
        android:icon="@mipmap/ic_launcher"
        android:label="@string/app_name"
        android:theme="@style/AppTheme">

        <meta-data
            android:name="asset_statements"
            android:resource="@string/asset_statements" />

        <activity android:name=".MainActivity">
            <intent-filter>
                <action android:name="android.intent.action.MAIN" />
                <category android:name="android.intent.category.LAUNCHER" />
            </intent-filter>
        </activity>
    </application>
</manifest>
```

完成上述步驟並發布新版 Android 應用程式後，支援 Digital Asset Links 的密碼管理工具 (例如 Google 密碼管理工具) 就能在使用者嘗試登入 `com.example.app` 時，建議他們使用為 `www.example.com` 儲存的憑證，反之亦然。

設定變更可能需要 1 到 2 週才會生效。

步驟 4 · 約 0 分鐘

4. 驗證設定

出貨前，請務必驗證 Digital Asset Links 設定。如果 JSON 格式有誤或檔案無法存取，系統會自動略過。

使用官方的[聲明產生器](#)和[驗證器](#)工具。

Google Digital Asset Links

HomeGuidesReferenceSamplesTools

Statement List Generator and Tester

Generate and save a statement file on your site to enable [App Linking](#) and [Credential Sharing](#), or test an existing statement file.

Setting up Credential Sharing allows Google Password Manager to seamlessly sign the user in across different apps and websites.

Relation type

Deep Linking

Hosting site domain

www.example.com

App package name

com.example.app

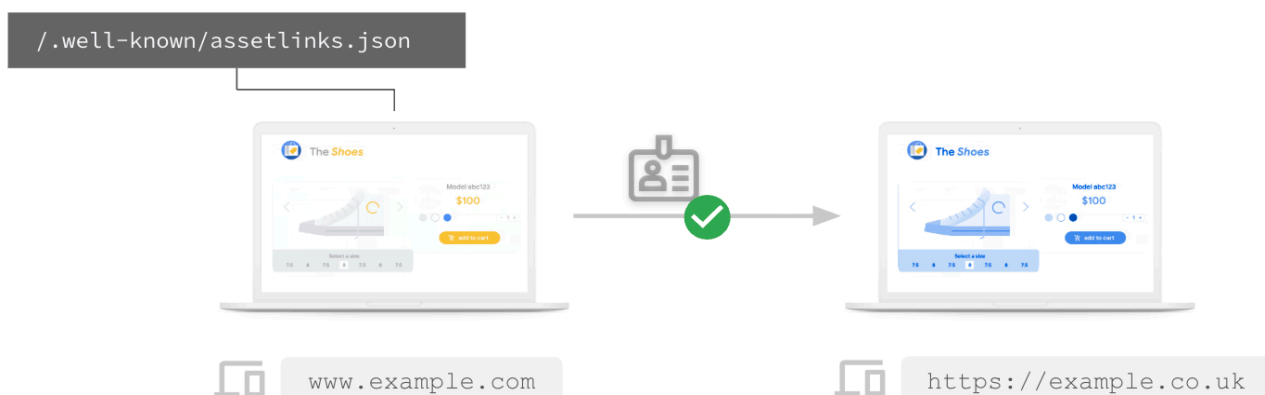
App package fingerprint (SHA256)

Generate statementorTest statement

- 1. 輸入您的網站網域和應用程式套件名稱。
- 2. 按一下「測試聲明」。
- 3. 這項工具會檢查 `assetlinks.json` 檔案是否正確代管，以及是否包含有效關聯。

步驟 5 · 約 0 分鐘

5. 在多個網站之間共用憑證



如果多個網站共用同一個登入系統 (例如 `example.com` 和 `example.co.uk`)，您可以將這些網站宣告為相關聯，以便共用憑證。

在多個網站之間共用密碼

如要在網站之間共用密碼，可以使用 `delegate_permission/common.get_login_creds` 宣告 `web` 對 `web` 關聯。

舉例來說，如要讓 `example.com` 與 `example.co.uk` 共用密碼，`https://example.com/.well-known/assetlinks.json` 上託管的 `assetlinks.json` 檔案必須包含以 `example.co.uk` 為目標的陳述式：

```
[{
  "relation": ["delegate_permission/common.get_login_creds"],
  "target": {
    "namespace": "web",
    "site": "https://example.co.uk"
  }
}]
```

同樣地，`https://example.co.uk/.well-known/assetlinks.json` 必須包含指定 `example.com` 的陳述式。

注意：Chrome 會自動在[同網站](#)之間分享已儲存的憑證 (例如 `www.example.com` 和 `m.example.com`)，但網站和 Android 應用程式 (包括應用程式 WebView) 之間的分享行為不同。如要整合應用程式，您必須在登入發生的子網域中，將有效的 `assetlinks.json` 檔案放在 `/.well-known/assetlinks.json`，藉此設定 Digital Asset Links (DAL)，啟用憑證共用功能。

在多個網站之間共用密碼金鑰

如要讓多個網站共用同一組密碼金鑰，這些網站必須使用相同的憑證方 ID (RP ID)。在 WebAuthn 和密碼金鑰中，RP ID 會依網域名稱指定憑證範圍。建立密碼金鑰時，系統會將其與特定 RP ID 綁定，且只能在該 ID 範圍內的網域使用。正確定義 RP ID 可確保子網域、跨網站來源和第一方行動應用程式提供順暢的密碼金鑰體驗。如要進一步瞭解如何設定 RP ID，請參閱「[瞭解憑證管理機構 ID \(RP ID\)](#)」。透過[相關來源要求](#)，網站可以指定允許使用其 RP ID 的其他來源，讓使用者在您經營的多個網站上重複使用同一組密碼金鑰。請注意，這與在網站和 Android 應用程式之間共用密碼金鑰不同，後者使用 Digital Asset Links 中的 `delegate_permission/common.handle_all_urls`。

舉例來說，如果想讓 `example.com` 和 `example.co.uk` 共用密碼金鑰，可以決定 `example.com` 是標準 RP ID。如要讓這項功能正常運作，`example.co.uk` 必須在 WebAuthn API 呼叫中使用 `rpId: 'example.com'`，且 `example.com` 必須在 `https://example.com/.well-known/webauthn` 託管檔案，才能將 `example.co.uk` 加入允許清單：

```
{
  "origins": [
    "https://example.co.uk"
  ]
}
```

這可讓 `example.co.uk` 建立及使用與 `example.com` 相關聯的密碼金鑰。

密碼管理工具會將憑證共用關係視為**遞移**。如果實體 A 和實體 B (A 和 B 可以是網站或應用程式) 都隸屬於實體 C，則 A 和 B 也會自動共用憑證。

步驟 6 · 約 0 分鐘

6. 結論

恭喜！您已成功設定憑證整合共用。

使用者現在可以在您的網站上儲存密碼和密碼金鑰，然後輕觸一下即可登入 Android 應用程式 (反之亦然)。只要稍做調整，就能大幅提升登入轉換率和使用者的滿意度。

後續步驟

- 請參閱 [Digital Asset Links 官方說明文件](#)。
 - 進一步瞭解[憑證共用基礎知識](#)。
 - 請參閱 [eBay 個案研究](#)，瞭解實際成效。
-